

PLAN DE RESPUESTA A INCIDENTE DE RANSOMWARE

Basado en el Marco de Ciberseguridad NIST

Caso de Estudio: TechCo

Preparado por:

Raul Velasquez

Seguridad en Redes y Sistemas

2025

1. Descripción del Incidente

TechCo, empresa proveedora de servicios en la nube, sufrió un ataque de ransomware originado por un correo de phishing. Un empleado descargó un archivo adjunto malicioso que permitió la instalación del ransomware en la red interna, propagándose rápidamente a servidores críticos y sistemas de backup.

Los atacantes exigieron 50 Bitcoins (más de \$1,000,000 USD) con un plazo de 72 horas, bajo amenaza de eliminar permanentemente todos los archivos cifrados.

2. Identificación

2.1 Activos Críticos Afectados

A continuación se identifican los activos comprometidos y las vulnerabilidades que facilitaron el ataque:

Activo	Descripción	Vulnerabilidad Identificada
Servidor de archivos	Documentos y datos operativos esenciales	Sin segmentación de red; accesible desde equipo comprometido
Base de datos de clientes	Información personal y financiera sensible	Sin controles de acceso diferenciado
Sistemas de backup	Copias de seguridad internas	Dentro de la misma red comprometida; cifrados por el ransomware
Correo corporativo	Canal de comunicación interna y externa	Empleados sin entrenamiento ante phishing

2.2 Vulnerabilidades Clave

- Ausencia de segmentación de red: los sistemas de producción y backups compartían la misma red.
- Sin monitoreo en tiempo real ni protocolo de alerta temprana.
- Personal sin capacitación ante técnicas de phishing.
- Backups accesibles desde la red principal, lo que permitió su cifrado.

3. Protección

Las siguientes medidas preventivas hubieran mitigado o evitado el incidente:

Medida Preventiva		Descripción
Segmentación de red		Separar redes de producción, backups y usuarios para limitar la propagación de malware.
Backups fuera de línea (offsite)		Mantener copias de seguridad en entornos aislados o en la nube, no accesibles desde la red principal.
Filtro de correo electrónico		Implementar herramientas anti-phishing y sandbox para analizar archivos adjuntos antes de su entrega.
Capacitación al personal		Entrenar a los empleados para identificar correos de phishing y reportarlos al equipo de seguridad.
Principio de mínimo privilegio		Restringir permisos de usuarios para que solo accedan a los recursos necesarios para su función.
Autenticación (MFA)	multifactor	Requerir MFA para accesos remotos, VPN y sistemas críticos.

4. Detección

La falta de monitoreo permitió que el ransomware se propagara sin ser detectado hasta que los empleados notaron la pérdida de acceso a los archivos. Las siguientes herramientas y métodos habrían permitido una detección temprana:

Herramienta / Método	Tipo	Utilidad en el Incidente
SIEM (ej. Splunk, IBM QRadar)	Monitoreo centralizado	Correlaciona eventos de múltiples fuentes y genera alertas en tiempo real.
EDR (ej. CrowdStrike, SentinelOne)	Detección en endpoint	Detecta comportamientos anómalos como cifrado masivo de archivos.
IDS/IPS de red	Detección de intrusiones	Identifica tráfico sospechoso de C2 (comando y control) del ransomware.
Honeypots / archivos señuelo	Detección temprana	Archivos cebo cuyo acceso o cifrado activa una alerta inmediata.

5. Respuesta

El plan de respuesta define los pasos a seguir desde la detección del incidente hasta su erradicación, con roles y responsabilidades claramente asignados:

#	Fase	Acción	Responsable
1	Contención inmediata	Aislar sistemas afectados de la red para detener la propagación.	Equipo de TI / Seguridad
2	Notificación interna	Alertar a la gerencia, equipo legal y CISO sobre el incidente.	CISO / Gerencia General
3	Análisis forense	Identificar vector de entrada, alcance del cifrado y variante del ransomware.	Analista Forense / SOC
4	Evaluación del rescate	Analizar opciones: NO pagar salvo última instancia. Consultar con autoridades (FBI, CISA).	Gerencia / Legal
5	Comunicación externa	Notificar a clientes afectados y reguladores según lo exija la ley (ej. GDPR, CCPA).	Relaciones Públicas / Legal
6	Erradicación	Eliminar el malware de todos los sistemas confirmando su limpieza con herramientas EDR.	Equipo de Seguridad

5.1 Comunicación

- Interna: usar canales alternativos (teléfono, correo personal) si los sistemas corporativos están comprometidos. Informar solo al personal esencial para evitar filtraciones.
- Externa: designar un vocero único. Notificar a clientes afectados con un mensaje claro y honesto. Coordinar con autoridades (FBI, CISA) antes de emitir declaraciones públicas.

6. Recuperación

Una vez erradicada la amenaza, se procede a restaurar las operaciones de manera ordenada y segura:

Etapas	Acciones
Restauración de datos	Recuperar desde backups externos/offsite verificados, en orden: datos críticos, luego sistemas secundarios.
Validación de integridad	Confirmar que los sistemas restaurados están limpios antes de reconectarlos a la red de producción.

Continuidad del negocio	Activar el Plan de Continuidad (BCP): habilitar acceso remoto seguro, priorizar servicios críticos para clientes.
Refuerzo de controles	Aplicar parches, cambiar credenciales, segmentar red y mover backups fuera de línea antes de regresar a producción.

7. Mejora Continua

La eficacia del plan se evalúa y mejora de forma continua a través de las siguientes actividades:

Actividad	Descripción
Reunión post-incidente	Sesión con todas las partes involucradas para revisar cronología, decisiones y resultados del plan.
Informe de lecciones aprendidas	Documentar qué funcionó, qué falló y qué debe mejorar en el plan de respuesta.
Simulacros (Tabletop Exercises)	Realizar ejercicios periódicos simulando ataques de ransomware para evaluar la preparación del equipo.
Revisión anual del plan	Actualizar el plan de respuesta al menos una vez al año o tras cada incidente de seguridad.

Integrar las lecciones aprendidas en el plan garantiza que TechCo esté mejor preparada ante futuros incidentes. El ciclo de mejora continua del NIST (Identificar → Proteger → Detectar → Responder → Recuperar) debe revisarse periódicamente para adaptarse a un panorama de amenazas en constante evolución.